Global Data Protection and Privacy Policy

Acme Corp and its wholly owned subsidiaries

Field	Value
Document ID	ACP-POL-014
Version	4.2 (supersedes 4.1 of 3 March 2025)
Classification	Internal
Effective date	1 January 2026
Next scheduled review	1 January 2027 (annual, or upon material regulatory change)
Policy owner	Chief Privacy Officer (CPO)
Approved by	Acme Corp Board Risk Committee, 12 November 2025
Applies to	All employees, contractors, interns, temporary staff, and third parties processing personal data on behalf of Acme Corp

This document is fictional and created for testing purposes. Any resemblance to real companies, people, or regulations is coincidental.

1. Purpose and Scope

This policy establishes the mandatory requirements for the collection, processing, storage, sharing, and disposal of personal data by Acme Corp ("Acme", "the Company") in all territories where it operates. It exists to protect the rights of individuals whose personal data Acme handles, to meet the Company's legal and contractual obligations, and to provide a single authoritative reference for privacy expectations worldwide.

The policy applies to every processing activity performed by or on behalf of Acme, regardless of format, system, or territory. It applies to personal data about customers, partners, suppliers, employees, candidates, and any other living individual. It does not apply to fully anonymised or aggregated data from which individuals cannot be re-identified using means reasonably likely to be used.

Where local law imposes stricter requirements than this policy, the stricter local requirement prevails and the local addendum recorded in the Regional Register of Variances takes precedence. Where this policy is stricter than local law, this policy prevails unless a documented exception has been granted under Section 18.

1.1 Territorial application

- All Acme-controlled entities in North America, the European Union, the United Kingdom, and the Asia-Pacific region.
- All processing performed by service providers acting as processors, regardless of where the processor is located.
- All processing performed by employees on personal devices, in transit, or in third-party facilities.

2. Definitions

Term	Definition
Personal data	Any information relating to an identified or identifiable natural person; includes identifiers such as name, email address, employee ID, IP address, and device identifiers.
Processing	Any operation performed on personal data, including collection, recording, storage, adaptation, consultation, use, disclosure, restriction, erasure, and destruction.
Data subject	The identified or identifiable natural person to whom personal data relates.
Controller	The entity that determines the purposes and means of processing. Acme Corp acts as controller for employee, marketing, and website visitor data.
Processor	An entity that processes personal data on behalf of a controller, such as a cloud hosting or analytics provider.
Special category data	Data revealing racial or ethnic origin, political opinions, religious beliefs, trade union membership, genetic or biometric data, health data, sex life, or sexual orientation.
DPIA	Data Protection Impact Assessment: a structured risk assessment required before high-risk processing begins.
ROPA	Records of Processing Activities: the internal register documenting all processing activities and their controls.
Personal data breach	A breach of security leading to accidental or unlawful destruction, loss, alteration, unauthorised disclosure of, or access to personal data.
Lead supervisory authority	The primary data protection authority for an entity's cross-border processing, determined by main establishment.

Term	Definition
Sub-processor	A processor engaged by another processor to carry out specific processing activities.
Pseudonymisation	Processing personal data so it can no longer be attributed to a specific individual without additional information kept separately.

3. Data Protection Principles

Acme processes personal data in accordance with the seven principles below. Every processing activity recorded in the ROPA must demonstrate compliance with each applicable principle, and the responsible Data Owner must attest to that compliance at each annual review.

(1) Lawfulness, fairness, transparency. Processing must rest on a documented lawful basis, must not be detrimental or misleading to the data subject, and must be described in an accessible privacy notice.

(2) Purpose limitation. Personal data must be collected for specified, explicit, and legitimate purposes and must not be further processed in a manner incompatible with those purposes. New purposes require a compatibility assessment approved by the Privacy Office.

(3) Data minimisation. Only data that is adequate, relevant, and limited to what is necessary may be collected. Product teams must justify every mandatory field on a collection form in writing.

(4) Accuracy. Personal data must be kept accurate and up to date. Customer profile data is verified at least once every 24 months; employee data is verified during each annual review cycle.

(5) Storage limitation. Personal data must be retained only as long as necessary for the stated purpose. The retention schedule in Section 9 is binding; ad-hoc retention decisions are prohibited.

(6) Integrity and confidentiality. Appropriate technical and organisational security measures must protect personal data, including encryption in transit (TLS 1.2 or higher) and at rest (AES-256).

(7) Accountability. The controller must be able to demonstrate compliance. Evidence includes DPIAs, ROPA entries, training records, access reviews, and vendor assessments.

4. Lawful Bases for Processing

Each processing activity must record exactly one lawful basis per purpose. The six recognised bases and their typical Acme use cases are set out below. Consent, where used, must be freely given, specific, informed, and unambiguous; pre-ticked boxes and bundled consent are prohibited.

Lawful basis	Typical Acme use cases
Contract performance	Fulfilment of a purchase, provision of a hosted service, payment processing, delivery of warranty support.
Legal obligation	Tax and accounting record retention, employment eligibility verification, responses to lawful authority requests.
Legitimate interests	Fraud prevention, network security logging, limited employee monitoring described in Section 14, B2B contact enrichment. Requires a documented Legitimate Interests Assessment (LIA form DP-05).
Vital interests	Emergency medical situations where disclosure is necessary to protect someone's life.
Public interest	Rarely applicable; only for tasks carried out in the public interest as defined by applicable law.
Consent	Marketing email subscriptions, non-essential cookies, publication of employee photographs, special category processing in HR programmes.

5. Data Subject Rights

Requests may be received through any channel, including email to privacy@acmecorp.example, the web form at acmecorp.example/privacy, or verbally to any employee, who must forward the request to the Privacy Office within two business days. Identity verification is mandatory before any response is released; where identity is doubtful, the Privacy Office may request government-issued identification and must respond within five business days while the statutory clock continues to run.

Right	Response timeframe	Owning team	Notes
Access (Art. 15 equivalent)	30 calendar days	Privacy Office	One free copy; additional copies charged at cost
Rectification	30 calendar days	Data Owner team	May be refused if accuracy is not established
Erasure	30 calendar days	Privacy Office + Data Owner	Refused where a legal retention duty applies
Restriction	5 business days to acknowledge	Privacy Office	Data retained but not processed
Portability	30 calendar days	Platform Engineering	Structured, machine-readable export (JSON or CSV)
Objection	30 calendar days	Privacy Office	Balancing test documented via form DP-08
Automated decision-making review	20 business days	Legal + Privacy Office	Human review available for scoring decisions with legal or similarly significant effects

Statutory maximum extension: where a request is complex, the response period may be extended by a further 60 days with written notice to the data subject within the initial 30-day window. Extensions must be approved by the DPO and logged in the Rights Register.

6. Records of Processing Activities

Every processing activity must be recorded in the central ROPA within 10 business days of its approval. The ROPA entry must include: the purpose, lawful basis, categories of data subjects, categories of personal data, categories of recipients, third countries involved and the transfer mechanism relied upon, retention periods, and a general description of security measures.

Data Owners are responsible for the accuracy of their ROPA entries. The Privacy Office audits a random sample of at least 15 percent of entries each quarter; material findings must be remediated within 30 calendar days.

7. Data Classification and Handling

All personal data assets must be classified using the four-level scheme below. Classification drives handling, storage, and sharing controls; where an asset qualifies for more than one level, the highest applies.

Level	Examples	Handling requirements
Public	Marketing material, public website content, published press releases.	No restriction beyond accuracy review before publication.

Level	Examples	Handling requirements
Internal	Day-to-day business documents without personal data or with low-sensitivity employee data.	Shareable with any employee; no external sharing without owner approval.
Confidential	Customer records, HR files, financial data, most personal data.	Need-to-know access; logged in the access register; encrypted at rest; no personal cloud storage.
Restricted	Special category data, authentication secrets, security configurations, live production data exports.	Named-individual access only; CPO and CISO dual approval; access expires after 90 days and must be re-approved.

Production databases containing Restricted data must never be used for demonstrations, testing, or analytics without irreversible masking approved by the Data Owner and the Privacy Office. Masked test data must be regenerated at least once every 6 months to prevent residual re-identification.

8. International Transfers

Personal data may be transferred outside the country of collection only where an approved transfer mechanism is in place. The Privacy Office maintains the Transfer Register listing every active transfer route, the mechanism relied upon, and the date of the most recent assessment.

Route	Mechanism	Review cadence
EU/EEA to United States	Standard contractual clauses plus transfer impact assessment	Reviewed annually by Legal
EU/EEA to India (Pune processing centre)	Standard contractual clauses, supplementary technical measures (encryption with EU-held keys)	Reviewed annually by Legal
UK to Australia	Adequacy-style local mechanism or SCCs as applicable	Reviewed every 24 months
Any territory to personal cloud storage	Prohibited	No exceptions granted to date

9. Retention and Disposal

The following retention schedule is binding on all Acme entities. Retention periods run from the end of the calendar year in which the record was created unless a different trigger is stated. Disposal must be irreversible: physical records are cross-cut shredded or destroyed by a certified contractor with a certificate of destruction; digital records are cryptographically erased or securely overwritten.

Data category	Retention period	Disposal method
Customer contract records	7 years after contract end	Secure digital erasure
Customer support tickets	3 years after closure	Secure digital erasure
Website access logs containing IP addresses	90 days	Automated purge job
Security incident and SIEM logs	12 months	Automated purge job
Employee personnel files	6 years after employment ends	Cross-cut shred + certified digital erasure
Job applications (unsuccessful)	6 months after decision	Secure digital erasure
Payroll records	7 years after tax year end	Secure digital erasure
Marketing consent and suppression records	Permanent (suppression list)	Never erased; minimal fields only
CCTV footage in common areas	30 days	Automatic overwrite
Finance and invoice records	7 years after fiscal year end	Secure digital erasure

Data category	Retention period	Disposal method
Backups containing personal data	35 days rolling	Cryptographic erasure of backup keys
Meeting recordings involving individuals	12 months	Secure digital erasure

Deletion jobs must complete within 7 days of the retention trigger expiring. Failed deletion jobs raise a P2 incident automatically and must be re-run within 48 hours. The Privacy Office receives a monthly deletion completion report summarising volumes by category.

10. Personal Data Breach Response

Any suspected breach must be reported to the Security Operations Centre immediately and in any case within one hour of discovery, at any time of day. The SOC operates a 24/7 hotline on +1-555-0142 and staffs a dedicated incident channel. Delayed reporting is itself a policy violation.

Following triage, the DPO assesses risk to individuals. Where the breach is likely to result in a risk to the rights and freedoms of individuals, the competent supervisory authority must be notified within 72 hours of Acme becoming aware of the breach. Where the risk is high, affected individuals must be notified without undue delay and in any case within five business days of the risk determination, using clear language and describing the mitigation steps taken.

Timeframe	Action	Owner	Notes
0-1 hour	Discovery and report to SOC	Any employee	Incident ticket opened; severity pre-set to at least P3
1-4 hours	Containment and initial assessment	SOC lead	Systems isolated; evidence preserved
4-24 hours	DPO engagement and risk analysis	DPO	Risk to individuals documented using the breach risk matrix
Up to 72 hours	Supervisory authority notification (if required)	DPO	Notification includes nature, categories, approximate numbers, measures taken
Up to 5 business days	Data subject notification (if high risk)	DPO + Communications	Individual advice on protective steps provided
Within 30 days	Post-incident review and remediation plan	CISO + CPO	Lessons learned recorded; controls updated

Fines and contractual penalties arising from breaches are tracked by Legal; the Board Risk Committee is briefed on any incident meeting the high-risk threshold within 10 business days of closure.

11. Privacy by Design and DPIAs

A DPIA must be completed and approved before any new processing operation that meets one or more of the following triggers:

- Systematic and extensive evaluation of personal aspects based on automated processing, including profiling, with legal or similarly significant effects.
- Processing of special category data or criminal offence data on a large scale.
- Systematic monitoring of a publicly accessible area on a large scale.
- Processing involving more than 10,000 data subjects within a 12-month period.
- Use of new technologies where the privacy impact is not yet well understood by Acme.

- Combination or matching of datasets from three or more sources.

DPIA approvals are valid for 24 months; material changes to the processing require a new assessment. The DPIA review SLA from complete submission to decision is 15 business days. Processing that cannot proceed without residual high risk must be escalated to the Board Risk Committee.

12. Vendor and Processor Management

All processors handling personal data must complete security due diligence before contract signature and re-assessment at least once every 24 months. The standard security review SLA is 25 business days from receipt of a complete vendor questionnaire.

Contracts with processors must include, at minimum: processing only on documented instructions, confidentiality commitments, security measures equivalent to those in Section 7, assistance obligations for data subject rights and breach notification, audit rights, and sub-processor flow-down terms. Processors must notify Acme of new sub-processors at least 30 days in advance; Acme may object within 15 days and require an alternative arrangement.

- High-risk processors (those handling Restricted data) additionally require an on-site or virtual assessment before go-live.
- Vendors located in jurisdictions without an approved transfer mechanism may not process Acme personal data.
- Vendor contracts must terminate data processing within 30 days of service end, with certification of deletion within 60 days.

13. Marketing and Consent

Electronic marketing to individuals requires affirmative opt-in consent captured with a clear description of purpose. Double opt-in (confirmation email) is mandatory for all marketing email lists. Consent records must store the timestamp, the wording shown, the source channel, and the version of the notice presented.

- Consent withdrawal requests must be honoured within five business days and must be as easy as giving consent.
- Suppression lists recording individuals who withdrew consent or objected are retained permanently and checked before every send.
- Purchase of third-party marketing lists is prohibited; Acme contacts only individuals who engaged directly with Acme.
- Each marketing email must include a working one-click unsubscribe; unsubscribe clicks are processed within one hour.

14. Employee Data and Monitoring

Acme processes employee data for employment administration, payroll, performance management, and security monitoring as described here. Employees receive a privacy notice at hire and whenever material changes occur.

Network and endpoint monitoring is permitted for security and productivity purposes under legitimate interests, subject to these limits:

- Keystroke logging and screenshot capture are prohibited absent an active investigation formally approved in writing by both the HR Director and the Legal Director.

- Monitoring findings unrelated to the authorised investigation scope must be disregarded and the material deleted within five business days.
- CCTV is restricted to physical security of premises; audio recording in work areas is prohibited except in designated compliance recording zones notified in advance.
- Employee browsing activity may be reviewed only in aggregate by default; individual review requires investigation approval as described above.

Employee data used for algorithmic performance scoring is subject to the automated decision-making review rights in Section 5, and any score must be explainable to the employee upon request within 20 business days.

15. Children's Data

Acme does not knowingly offer services directly to children under 16. Where a service is directed at, or knowingly used by, individuals under 16, verifiable parental consent must be obtained before collection. Personal data of children under 13 is never collected in any Acme programme without explicit legal review and written CPO approval.

If collection of a child's personal data is discovered without a lawful basis, the Privacy Office must restrict processing within 24 hours and arrange erasure within five business days.

16. Training and Awareness

All new joiners must complete privacy awareness training within 14 calendar days of start date. Access to systems processing Confidential or Restricted data is provisionally granted but automatically revoked at day 15 for anyone who has not completed training.

Audience	Module	Duration	Assessment	Remediation
All employees	Annual refresher	45 minutes	Pass mark 85%	Two retake attempts, then manager escalation
Engineers and data stewards	Annual advanced module	90 minutes	Pass mark 85%	Covers DPIA inputs and breach recognition
Marketing staff	Annual consent and direct marketing module	60 minutes	Pass mark 90%	Mandatory before campaign tooling access
New joiners	Onboarding module	30 minutes	Pass mark 80%	Within 14 calendar days of start

Simulated phishing exercises run quarterly. Employees who fail three consecutive simulations must complete one-to-one coaching with the Security Awareness team within 10 business days.

17. Roles and Responsibilities

Role	Responsibilities
Chief Privacy Officer	Owns this policy; approves exceptions; briefs the Board Risk Committee quarterly.
Data Protection Officer	Independent monitoring; supervisory authority liaison; DPIA sign-off; breach risk determinations.
Data Owners	Business leaders accountable for accuracy, retention, and lawful basis of their processing activities.
Data Stewards	Day-to-day operational owners; maintain ROPA entries; approve access requests for their datasets.

Role	Responsibilities
Security Operations Centre	24/7 breach detection and intake; containment; evidence preservation.
All personnel	Report suspected breaches within one hour; complete training; follow handling rules for their data classifications.

18. Exceptions and Waivers

Exceptions to this policy must be requested via form DP-EX submitted to the Privacy Office. Each waiver must state the clause in question, the business justification, the compensating controls, the affected data categories, and an expiry date. The CPO is the sole approver; the CISO must co-approve any waiver affecting Section 7 handling rules.

- Maximum waiver duration is 6 months; renewal requires a fresh request and fresh justification.
- All active waivers are reviewed at the quarterly Privacy Governance Board.
- Waivers involving special category data additionally require Legal Director approval.
- Expired waivers that have not been renewed are automatically revoked and the underlying processing must stop.

19. Non-Compliance

Breaches of this policy may result in disciplinary action up to and including termination of employment or contract, and may be reported to the relevant authorities where required by law. The table below sets out the standard disciplinary matrix; aggravated cases (wilful misconduct, concealment, or harm to data subjects) jump directly to the highest applicable level.

Offence	First occurrence	Second occurrence	Third / aggravated
Late training completion	Documented reminder	Final written warning	Contract termination review
Failure to report a breach within 1 hour after knowledge	Written warning	Final written warning	Termination review + refresher training
Unauthorised access to Confidential data	Final written warning	Termination review	Termination + potential legal action
Sharing Restricted data outside approved channels	Final written warning	Termination	Termination + regulatory self-report assessment
Concealing a breach or destroying evidence	Termination	Termination	Termination + legal action

20. Related Documents and Escalation

- Security and Access Policy (ACP-SEC-002) - device, password, and VPN controls.
- Acceptable Use Policy (ACP-SEC-005) - corporate systems and network use.
- Data Retention Schedule (ACP-OPS-021) - operational detail supporting Section 9.
- Incident Response Plan (ACP-SEC-009) - technical breach handling runbook.
- Employee Handbook (ACP-HR-001) - general employment terms and benefits.

Escalation contacts: Privacy Office privacy@acmecorp.example (response within one business day); DPO on-call hotline +1-555-0166 (24/7); Security Operations Centre hotline +1-555-0142 (24/7); Legal Director legal@acmecorp.example (escalations and supervisory authority correspondence).

21. Revision History

Version	Date	Summary of change	Approved by
1.0	12 Jan 2021	Initial privacy framework	Chief Privacy Officer
2.0	4 Apr 2022	Added international transfers chapter	Chief Privacy Officer
3.1	18 Sep 2023	Breach timelines aligned to 72-hour authority notification	DPO
4.0	7 Feb 2025	Full rewrite; four-level classification; new disciplinary matrix	Chief Privacy Officer
4.1	3 Mar 2025	Retention table updated for access logs (180 to 90 days)	DPO
4.2	1 January 2026	DPIA threshold lowered to 10,000 data subjects; training pass marks added	Chief Privacy Officer

Appendix A - Data Category Reference

Category	Classification	Role	Note
Customer identity	Confidential	Controller	Customer records
Employee payroll	Confidential	Controller	Payroll records
IP-addressed web logs	Internal	Controller	90-day purge
Biometric access control data	Restricted	Controller	Never stored beyond 30 days
Helpdesk ticket text	Confidential	Controller	May contain special category data
Cloud analytics events	Internal	Processor (analytics vendor)	Pseudonymised at collection

Appendix B - Regional Privacy Contacts

Region	Email	Phone	Notes
EU/EEA	privacy.eeu@acmecorp.example	+31-20-555-0110	Amsterdam main establishment
United Kingdom	privacy.uk@acmecorp.example	+44-20-555-0121	London representative office
United States	privacy.us@acmecorp.example	+1-555-0133	New York head office
Asia-Pacific	privacy.apac@acmecorp.example	+61-2-555-0148	Sydney regional hub
Global DPO	dpo@acmecorp.example	+1-555-0166	24/7 hotline

Appendix C - Forms and Templates

Form	Purpose
DP-01	DPIA initiation and report template
DP-05	Legitimate Interests Assessment
DP-08	Objection balancing test
DP-EX	Policy exception request
DP-BR	Breach notification internal form
DP-RR	Rights request intake form